# 海外におけるオープン API のセキュリティ要件集に関する一考察

宇根 正志 [1,*]

**概要**：オープン API を活用した金融サービスのセキュリティを確保するうえで，API システムにおいて認可処理のプロトコルを適切に実装することが必要である．認可処理のプロトコルの標準仕様 OAuth 2.0 のセキュリティ要件集として，2025 年 2 月に FAPI 2.0 が標準化されており，日本の金融機関やフィンテック事業者は FAPI 2.0 を満たすようにセキュリティ対策を選択して API システムを構築することができる．また，海外の金融サービスと同等のセキュリティを確保するという観点からは，海外の既存のセキュリティ要件集を参照することも重要である．実際，FAPI 2.0 と海外のセキュリティ要件集を比較したところ，FAPI 2.0 よりもリスク低減に資するセキュリティ要件が存在していた．例えば，認可コード・フローの使用，アクセス・トークンや各種リクエストの有効期間の設定などに関するセキュリティ要件である．金融機関やフィンテック事業者は，FAPI 2.0 に加えて，こうしたセキュリティ要件も考慮して API システムを設計することが望ましい．

**キーワード**：オープン API，セキュリティ要件集，認可，FAPI 2.0，OAuth 2.0

# A Study on Security Profiles for Foreign Open APIs

Masashi Une[1,*]

***Abstract***: In order to ensure the security of financial services utilizing an open API, it is necessary to appropriately implement an authorization protocol in API systems. In February 2025, FAPI 2.0 has been standardized as the security profile for OAuth 2.0 which is the standard technical specification for the authorization protocol. Japanese financial institutions and fintech companies can select security measures and develop API systems in such a way to meet security requirements specified in FAPI 2.0. From a viewpoint of achieving the security equal to that of foreign financial services, it is important to refer to existing foreign security profiles. We compared several foreign security profiles with FAPI 2.0. As the results, we found that foreign profiles included requirements which could be more effective than those of FAPI 2.0 to mitigate security risks. For instance, the usage of the authorization code flow, the setting of life time of access tokens and request messages, and so on. Financial institutions and fintech companies should take into consideration not only FAPI 2.0 but also these requirements when designing API systems.

***Keywords***: Authorization, FAPI 2.0, OAuth 2.0, Open API, Security Profile

## 1. はじめに

オープン API（application programming interface）は，API の提供者が外部の組織に使用させるために公開した API を指す．金融分野では，金融機関がオープン API を提供し，電子決済等代行業者などのフィンテック事業者が API を用いて顧客の口座の取引情報を取得して顧客に提供する参照系サービスや，決済の実行を金融機関に指示する更新系サービスが知られている．

金融機関は，オープン API を活用したサービスのセキュリティを確保するうえで，顧客の情報へのアクセスをフィンテック事業者に許可するための処理（認可処理）を適切に実施する必要がある．認可処理に問題があると，第三者がフィンテック事業者になりすまし，顧客の情報を横取りするなどの事象が発生する可能性がある．認可処理に関するセキュリティ要件を適切に設定し，それを満たすようにセキュリティ対策を選択・実施することが求められる．

日本では，認可処理のプロトコルの標準仕様 OAuth 2.0 に基づく認可処理が推奨されている[1]．ただし，OAuth 2.0 を実装する際のセキュリティ要件をまとめたドキュメント（セキュリティ要件集）は，本稿執筆時点において筆者が知る限り，金融分野の業界団体などによって公表されているものはない．金融機関やフィンテック事業者が個別にセキュリティ要件を検討・設定しているのが実情である．

海外では，オープン API における認可処理のプロトコルとして OAuth 2.0 が採用され，そのセキュリティ要件集として FAPI 1.0（Financial-Grade API Security Profile 1.0）[2][3] が参照されるケースが目立つ．イギリスの Open Banking では，金融機関は FAPI 1.0 に準拠したセキュリティ対策を実施することが必須とされている．ブラジルの Open Finance やオーストラリアの Consumer Data Right では，FAPI 1.0 をベースとしつつ，より高いセキュリティの実現に資する独自の要件がそれぞれのセキュリティ要件集に盛り込まれている．このように，各国のセキュリティ要件集は，FAPI 1.0 をベースラインとしながらも異なる要件を含んでいる．

FAPI 1.0 については，OpenID Foundation によって 2021

1 日本銀行金融研究所
Institute for Monetary and Economic Studies, Bank of Japan
* masashi.une@boj.or.jp

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

年 3 月に標準化された後，セキュリティの向上などを企図して改訂され，後継として FAPI 2.0（FAPI 2.0 Security Profile）[4]が 2025 年 2 月に公表された．FAPI 2.0 では，例えば，①認可の内容に関する情報の保護，②使用する暗号アルゴリズムの安全性，③金融機関やフィンテック事業者による顧客への情報提供に関するセキュリティ要件が追加されている．今後，FAPI 2.0 が FAPI 1.0 に代わってセキュリティ要件集のベースラインとして広く参照される可能性が高い．

日本の金融機関やフィンテック事業者は，海外のオープン API と遜色ないセキュリティを実現するうえで，FAPI 2.0 のセキュリティ要件を充足するとともに，既存の海外のセキュリティ要件集も参照することが重要である．サイバーセキュリティの世界では，セキュリティのレベルが相対的に低い先が攻撃の対象となる傾向がある．このため，自社の API システムのセキュリティ要件を，FAPI 2.0 や海外のセキュリティ要件集に含まれる要件と少なくとも同等になるように設定することが望ましい．こうした観点から，海外のセキュリティ要件集の内容も把握しておくことが有用である．

2 節ではオープン API を用いた金融サービスの処理例を紹介する．3 節では FAPI 2.0 の主なセキュリティ要件を説明する．4 節では，海外のオープン API の事例として，イギリス，ブラジル，オーストラリア，欧州連合の事例を紹介し，セキュリティ要件集を FAPI 2.0 と比較・考察する．

なお，本稿で示されている意見や見解は筆者個人に属し，日本銀行の公式見解を示すものではないことを予め断っておく．

## 2. オープン API による金融サービスの処理例

ここでは，イギリスの Open Banking における口座情報の取得と決済の実行に関する処理例（Read-Write API Profile バージョン 4.0.1）[5]を紹介する．

### 2.1 エンティティ

登場する主なエンティティは以下のとおりである．

- 決済サービスの顧客（PSU：payment service user）
- 決済用の口座を管理しつつ決済サービスを提供する金融機関（ASPSP：account servicing payment service provider）
- 決済サービスの顧客と金融機関を仲介しつつ，決済に関連するサービスを提供するフィンテック事業者（TPP：third party provider）

フィンテック事業者として，決済サービスの顧客に口座の取引履歴などの情報（口座情報）を提供する場合（AISP：account information service provider）や，決済の処理を金融機関に依頼する場合（PISP：payment initiation service provider）が想定されている．AISP と PISP は，それぞれ参照系サービス，更新系サービスを提供するフィンテック事業者に対応する．

### 2.2 口座情報の取得の処理例

フィンテック事業者が金融機関から口座情報を取得する際の処理フローは，フィンテック事業者による処理内容の登録，金融機関による顧客の同意の確認，口座情報の提

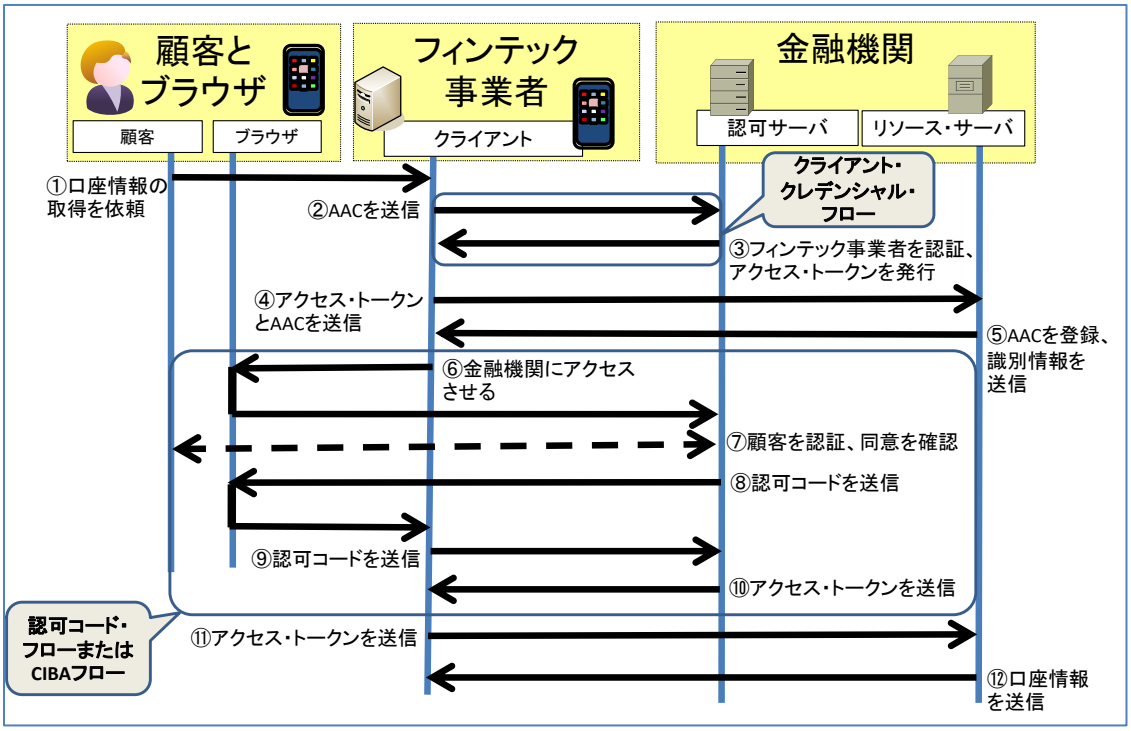



図 1　口座情報取得の処理フローの例

Figure 1　An Example of an Operational Flow of Obtaining Account Information

© 2026 Information Processing Society of Japan

供という流れとなる（図 1 参照）[6].

**【フィンテック事業者による処理内容の登録】**

① 顧客（PSU）はフィンテック事業者に口座情報の取得を依頼する.

② フィンテック事業者は処理の内容を特定するデータ AAC（account-access-consent resource） を金融機関（認可サーバ）に送信する.

③ 金融機関はフィンテック事業者を認証しアクセス・トークンを発行する.

④ フィンテック事業者はアクセス・トークンと AAC を金融機関（リソース・サーバ）に送信する.

⑤ 金融機関は AAC を登録し，その識別情報をフィンテック事業者に送信する.

**【金融機関による顧客の同意の確認】**

⑥ フィンテック事業者は顧客のブラウザを金融機関（認可サーバ）にアクセスさせる（認可リクエスト）.

⑦ 金融機関は顧客を認証し，AAC の内容に同意していることを顧客に確認する（同意認可〈consent authorization〉）.

⑧ 金融機関は顧客のブラウザを経由してフィンテック事業者に認可コードを送信する（認可レスポンス）.

⑨ フィンテック事業者は認可コードを金融機関に送信し，アクセス・トークンを要求する（トークン・リクエスト）.

⑩ 金融機関はフィンテック事業者にアクセス・トークンを送信する（トークン・レスポンス）.

**【口座情報の提供】**

⑪ フィンテック事業者は金融機関（リソース・サーバ）にアクセス・トークンを送信する（リソース・リクエスト）.

⑫ 金融機関は AAC で指定された口座情報をフィンテック事業者に送信する.

上記のうち，②と③の処理は OAuth 2.0 で規定されているクライアント・クレデンシャル・フローに基づいて実行される. ⑥から⑩の処理は認可コード・フローまたは CIBA（Client Initiated Backchannel Authentication）フローに基づいて実行される.

### 2.3 決済の実行の処理例

顧客がフィンテック事業者を介して金融機関に決済の実行を依頼する場合，フィンテック事業者による処理内容の登録，金融機関による顧客の同意の確認，決済の実行という流れとなる（図 2 参照）[7].

**【フィンテック事業者による処理内容の登録】**

① 顧客はフィンテック事業者に決済の実行を依頼する.

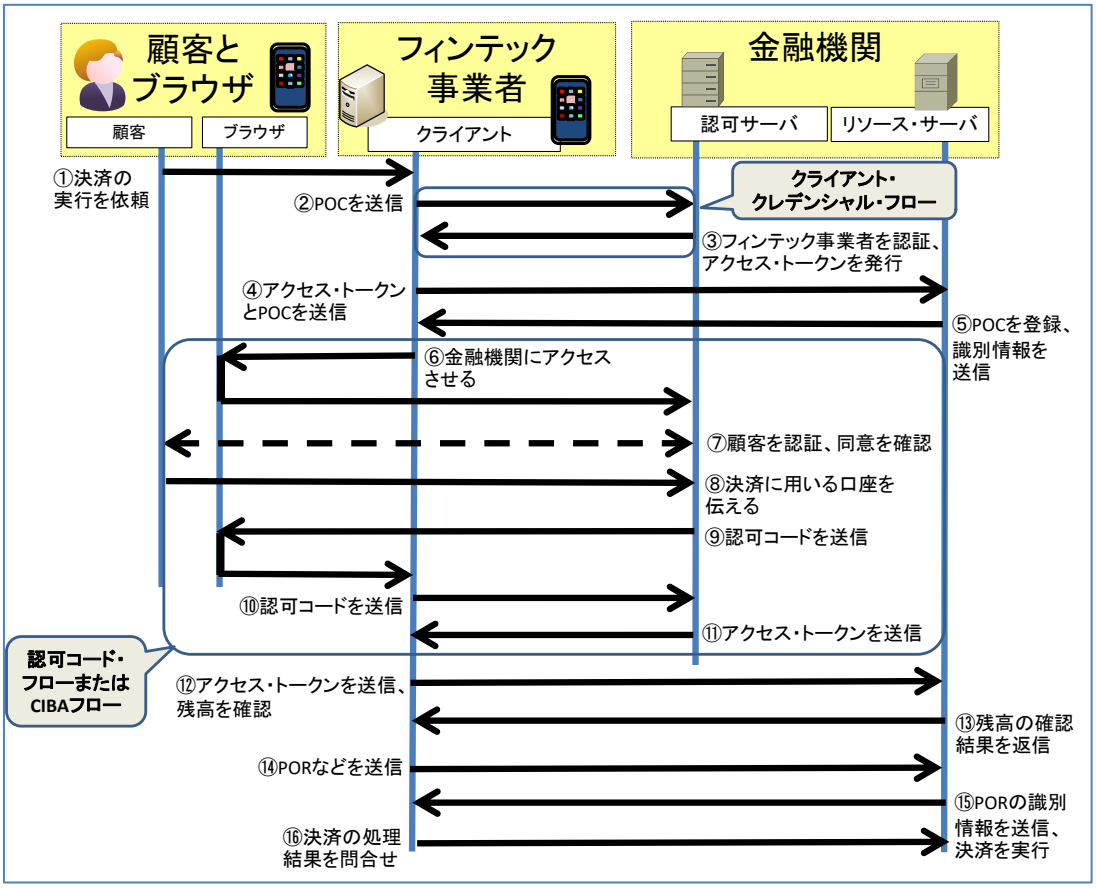



図 2　決済の実行の処理フローの例

Figure 2　An Example of an Operational Flow of Initiating Payment

© 2026 Information Processing Society of Japan

② フィンテック事業者は決済の処理の内容を示すデータ POC（payment-order consents resource）を金融機関（認可サーバ）に送信する．
③ 金融機関はフィンテック事業者を認証しアクセス・トークンを発行する．
④ フィンテック事業者は金融機関（リソース・サーバ）にアクセス・トークンと POC を送信する．
⑤ 金融機関は POC を登録し，フィンテック事業者にその識別情報を送信する．

**【金融機関による顧客の同意の確認】**

⑥ フィンテック事業者は顧客のブラウザを金融機関（認可サーバ）にアクセスさせる（認可リクエスト）．
⑦ 金融機関は顧客を認証し，POC の内容に同意していることを顧客に確認する（同意認可）．
⑧ 顧客は決済に用いる口座を金融機関に伝える．
⑨ 金融機関は，顧客のブラウザを経由してフィンテック事業者に認可コードを送信する（認可レスポンス）．
⑩ フィンテック事業者は認可コードを金融機関に送信し，アクセス・トークンを要求する（トークン・リクエスト）．
⑪ 金融機関はアクセス・トークンをフィンテック事業者に送信する（トークン・レスポンス）．

**【決済の実行】**

⑫ フィンテック事業者はアクセス・トークンを金融機関（リソース・サーバ）に送信し，口座に残高が十分に存在することを確認する（funds confirmation）．
⑬ 金融機関は口座の残高の確認結果をフィンテック事業者に返信する．
⑭ フィンテック事業者は，決済の処理内容を示すデータ POR（payment-order resource）をその識別情報とともに金融機関に送信する．
⑮ 金融機関は POR の識別情報をフィンテック事業者に送信し，決済の処理を実行する．
⑯ フィンテック事業者は POR の識別情報などを金融機関に送信し，決済の処理結果を問い合わせる．

上記のうち，②と③はクライアント・クレデンシャル・フローに基づいて実行される．⑥から⑪は，認可コード・フローまたは CIBA フローに基づいて実行される．

## 3. FAPI 2.0 の概要

### 3.1 セキュリティ目標

FAPI 2.0 のセキュリティ目標は OpenID Foundation の攻撃者モデルにおいて以下のとおり示されている[8]．攻撃者が特定のフィンテック事業者や金融機関の顧客としてアカウントを保持し，（自分以外の）他の顧客に対して攻撃を試みる状況を想定している．

- 攻撃者が，他の顧客の情報にアクセスしたり，（他の顧客が権限を有する）決済の処理を実行したりすることができない（不正アクセスなどの防止）．
- 攻撃者が，特定のフィンテック事業者のサービスにおいて他の顧客のアカウントへログインすることができない（不正ログインの防止）．
- 攻撃者が，特定の金融機関において顧客として保持しているアカウントへ他の顧客を誘導したり，特定のフィンテック事業者のサービスにおいて顧客として保持しているアカウントへ他の顧客を誘導したりすることができない（他の顧客の誘導の防止）．

### 3.2 想定環境

FAPI 2.0 の攻撃者モデルに記載されている主な想定環境は以下のとおりである．

- 各エンティティは TLS（バージョン 1.2，または，それよりも新しいバージョン）による暗号通信を実施するほか，TLS のサーバ証明書を検証する．
- TLS は適切に動作し，通信データの一貫性や機密性が確保される．
- 各エンティティは暗号化されたデータの復号鍵と署名検証鍵を安全に入手する．
- 顧客が使用する（端末などの）機器やブラウザは期待通りに動作する．
- 攻撃者によって悪用されていないエンティティは期待通りに動作する．
- フィンテック事業者や金融機関（認可サーバ）による顧客の登録・身元確認，当人確認，ID・アクセス管理は期待通りに実施される．
- 顧客による各セッションは他の顧客や攻撃者に対して適切に保護される．
- フィンテック事業者は，金融機関（認可サーバ）へのアクセス先の情報を安全に入手し，適切に金融機関へアクセスする．
- 認可コードやアクセス・トークンなどの漏洩を引き起こす実装上の不具合（例えば，データベースの設定ミス，OS やブラウザの設定ミスなど）は生じない．

### 3.3 主なセキュリティ要件

FAPI 2.0 の主なセキュリティ要件は以下のとおりである．

- 【コンフィデンシャル・クライアントの指定】フィンテック事業者は，クライアント認証に用いる署名生成鍵などの秘密情報を保持する．
- 【メタデータの提供方法の指定】金融機関はフィンテック事業者に自分のメタデータを RFC 8414 や OpenID Connect Discovery によって適切に提供する．
- 【認可フローの指定】金融機関は implicit flow や resource owner password credential flow による認可リクエストを拒否する．
  - ✓ この結果，認可コード・フローとクライアント・クレデンシャル・フローのみが使用可能である．
- 【クライアント認証方法の指定】金融機関によるフィ

© 2026 Information Processing Society of Japan

ンテック事業者の認証方法は MTLS（Mutual Transport Layer Security）に基づくクライアント認証（以下，OAuth MTLS） または private_key_jwt とする．

- 【認可リクエストの保護】金融機関は PAR（Pushed Authorization Request）をサポートし，PAR を使用しない認可リクエストを拒否する．
- 【PAR の有効期間の設定】金融機関は PAR による認可リクエストの登録の有効期間（登録完了時点から失効までの時間）を 600 秒未満に設定する．
- 【金融機関（認可サーバ）の検証】フィンテック事業者は認可レスポンス受信時に認可コードの発行者の識別情報（iss）を用いて金融機関を特定・検証する．
- 【認可コードの再使用の禁止】金融機関は使用済みの認可コードによるトークン・リクエストを拒否する．
- 【認可コードの有効期間の設定】金融機関は認可コードの有効期間を 60 秒未満とする．
- 【署名用のアルゴリズムの指定】金融機関とフィンテック事業者は通信メッセージ（JSON Web Token）で用いる署名用アルゴリズムとして，RSA-PSS，ECDSA，EdDSA のいずれかを用いる．RSA の最小鍵長を 2048 ビット，ECDSA または EdDSA の最小鍵長を 224 ビットとする．
- 【認可コードの不正使用防止】金融機関はフィンテック事業者に PKCE（Proof of Key for Code Exchange）の使用を要求する．
- 【認可レスポンスの保護】金融機関は認可レスポンス（認可コードを含む）を暗号化されていないネットワーク上で送信しない．
- 【アクセス・トークンの不正使用防止】金融機関は記名式トークン（sender-constrained access token）のみを発行し，送信元の確認方法として OAuth MTLS または DPoP（Demonstrating Proof of Possession）を用いる．
- 【リフレッシュ・トークンのローテーションの禁止】金融機関は原則としてリフレッシュ・トークンのローテーションを実施しない．
- 【金融機関による顧客への情報提供】金融機関は顧客が認可の内容を正しく認識したうえで認可の処理を開始できるように必要な情報（例えば，クライアントの識別子，認可の範囲）を顧客に提供することが望ましい（不正サイトへの誘導や認可内容の誤解の防止）．
- 【フィンテック事業者による顧客への情報提供】フィンテック事業者は顧客の同意によってのみ認可処理を開始する．顧客が認可処理の開始を正しく認識するように情報を顧客に提供することを通じて，認可処理の開始を保護する．

## 4. 海外のセキュリティ要件集と FAPI 2.0 の比較

本節では，海外のオープン API の事例として，イギリスの Open Banking，ブラジルの Open Finance，オーストラリアの Consumer Data Right，欧州連合の openFinance API Framework を取り上げる．これらのうち，独自のセキュリティ要件を設定しているブラジル，オーストラリア，欧州連合のケースに関して FAPI 2.0 と比較する．

### 4.1 Open Banking

イギリスでは，2017 年に競争・市場庁（Competition and Markets Authority）が金融サービスの向上や競争促進などを目的として Open Banking を開始した[9]．金融機関が保持している顧客情報の提供や決済の実行に加えて，住宅ローンをはじめとする融資・保険・身元確認などのサービスが提供されている[10]．各種の技術仕様やセキュリティ要件の策定，Open Banking の利用に関する統計情報の公表は，Open Banking Limited によって行われている[11]．

API の技術仕様 Read-Write API Profile では，金融機関やフィンテック事業者が FAPI 1.0 のセキュリティ要件を満たすように実装することが必須とされており，独自のセキュリティ要件集は策定されていないようである[12]．

### 4.2 Open Finance

#### 4.2.1 概要

2021 年，通貨政策や信用制度に関する最高意思決定機関である国家通貨審議会（National Monetary Council）とブラジル中央銀行は，金融サービスにおけるオープン API の取組みとしてオープン・バンキングを開始した[13]．当初は，オープン API の対象が金融機関の各種サービスに関する情報や顧客データの提供，決済の処理に限定されていたが，2022 年から住宅ローンや保険などに対象が拡大され，呼称もオープン・ファイナンスに変更された．技術仕様の策定・管理，API の使用状況を示す統計情報の公表などは，オープン・ファイナンス協会（Associação Open Finance）によって行われている．

API のセキュリティ要件集 Open Finance Brasil Financial-Grade API Security Profile は，実装者向けの最新バージョン（Implementers Draft 3）が 2024 年 5 月に発表されている[14]．この要件集は，FAPI 1.0 をベースとしつつ，より高いレベルのセキュリティを達成するために独自に策定されている．

#### 4.2.2 主なセキュリティ要件

このセキュリティ要件集に記載されている主なセキュリティ要件は以下のとおりである．

- 【フィンテック事業者の認証方法の指定】金融機関はフィンテック事業者の認証に private_key_jwt を使用する．
- 【メタデータの提供方法の指定】金融機関はメタデータを RFC 8414 または OpenID Connect Discovery による方法で提供する．
- 【PAR の必須化】金融機関はフィンテック事業者に対して PAR の実行を要求する．

© 2026 Information Processing Society of Japan

- 【PAR の有効期間の設定】金融機関は PAR による認可リクエストの登録の有効期間（登録完了時点から失効するまでの時間）を 60 秒以上とする．
- 【PKCE の必須化】金融機関はフィンテック事業者に対して PKCE の使用を要求する．
- 【アクセス・トークンの有効期間の設定】金融機関はアクセス・トークンの有効期間を 300 秒から 900 秒の間に設定する．
- 【リフレッシュ・トークンのローテーションの禁止】金融機関は原則としてリフレッシュ・トークンのローテーションを実施しない．
- 【暗号アルゴリズムの指定】金融機関とフィンテック事業者は，通信メッセージへ付与する署名用のアルゴリズムとして RSA-PSS（ハッシュ関数として SHA-256 を使用）を用いる．また，通信メッセージの暗号化に用いるアルゴリズムとして，公開鍵暗号には RSA-OAEP，共通鍵暗号には AES（256 ビット鍵長）を用いる．
- 【TLS に用いる暗号スイートの指定】金融機関は TLS において用いる暗号アルゴリズムの組合せ（暗号スイート）として以下をサポートする．
  - 鍵共有：ECDHE，署名：RSA，共通鍵暗号：AES（128 ビット鍵長），ハッシュ関数：SHA-256
  - 鍵共有：ECDHE，署名：RSA，共通鍵暗号：AES（256 ビット鍵長），ハッシュ関数：SHA-384

#### 4.2.3 FAPI 2.0 との比較

**〈FAPI 2.0 と整合的な要件〉**

- フィンテック事業者の認証方法
- PAR の必須化
- PKCE の必須化
- リフレッシュ・トークンのローテーションの禁止
- 暗号アルゴリズムの指定
- コンフィデンシャル・クライアントの指定

これらのうち，コンフィデンシャル・クライアントの指定に関する要件は明記されていないが，フィンテック事業者の認証方法として private_key_jwt を指定しており，それを実現するためにはフィンテック事業者は署名生成鍵を保持する必要がある．したがって，フィンテック事業者がコンフィデンシャル・クライアントであることを要求しているといえる．

**〈FAPI 2.0 よりもリスク低減に資する要件〉**

アクセス・トークンの有効期間に関する要件は，Open Finance のセキュリティ要件集に含まれているものの，FAPI 2.0 には含まれていない．アクセス・トークンの有効期間の設定は，アクセス・トークンが不正に使用される時間を制限するという点で望ましく，リスク低減に資する要件といえる．

### 4.3 Consumer Data Right

#### 4.3.1 概要

公正な企業活動や消費者保護に関する政策の立案・執行を担当する競争消費者委員会（Australian Competition and Consumer Commission）は，2020 年，オープン API を介して顧客情報を適切に保護しつつ流通させる取組みとして Consumer Data Right を開始した[15]．

API の技術仕様やセキュリティ要件集はデータ標準化機関（Data Standards Body）によって策定・管理されている[16]．セキュリティ要件集 Information Security Profile ついては，FAPI 1.0 をベースとしつつ独自に策定されている[17]．

#### 4.3.2 主なセキュリティ要件

セキュリティ要件集に含まれている主なセキュリティ要件は以下のとおりである．

- 【フィンテック事業者の認証方法】金融機関はフィンテック事業者の認証方法として OAuth MTLS を使用せず，private_key_jwt などを使用する．
- 【コンフィデンシャル・クライアントの指定】金融機関はコンフィデンシャル・クライアントのみをサポートする．
- 【認可コード・フローの使用】フィンテック事業者は認可コード・フローのみを使用する．
- 【認可コードの再使用の禁止】フィンテック事業者は認可コードを再使用しない．
- 【PAR の必須化】フィンテック事業者は PAR を使用する．
- 【PAR の有効期間の設定】金融機関は PAR による認可リクエストの登録の有効期間を 10 秒から 90 秒の間に設定する．
- 【PKCE の必須化】フィンテック事業者は PKCE を使用する．
- 【各種リクエストの有効期間の設定】フィンテック事業者は各種リクエストの有効期間を 60 分以下に設定する．
- 【アクセス・トークンの有効期間の設定】金融機関はアクセス・トークンの有効期間を 120 秒から 600 秒の間に設定する．
- 【リフレッシュ・トークンのローテーションの禁止】金融機関はリフレッシュ・トークンのローテーションを実施してはならない．
- 【リフレッシュ・トークンのステータス確認の方法】金融機関は，フィンテック事業者がリフレッシュ・トークンのステータス（失効の有無など）を確認するための方法[18]をサポートする．
- 【暗号アルゴリズムの指定】金融機関とフィンテック事業者は，通信メッセージへ付与する署名用のアルゴリズムとして RSA-PSS または ECDSA（いずれもハッシュ関数は SHA-256）を用いる．通信メッセージの暗

© 2026 Information Processing Society of Japan

号化に用いるアルゴリズムとして，公開鍵暗号には RSA-OAEP，通鍵暗号には AES（128 ビット鍵長または 256 ビット鍵長）を用いる．

#### 4.3.3 FAPI 2.0 との比較

**〈FAPI 2.0 と整合的な要件〉**

4.3.2 節のセキュリティ要件のうち，以下が FAPI 2.0 と整合的である．

- フィンテック事業者の認証方法
- PAR の必須化
- PKCE の必須化
- 認可コードの再使用の禁止
- リフレッシュ・トークンのローテーションの禁止
- 暗号アルゴリズムの指定
- コンフィデンシャル・クライアントの指定

**〈FAPI 2.0 よりもリスク低減に資する要件〉**

以下のセキュリティ要件はいずれも FAPI 2.0 に含まれておらず，リスク低減に資する内容である．

- アクセス・トークンの有効期間の設定
- PAR の有効期間の設定
- 各種リクエストの有効期間の設定
- 認可コード・フローの使用

これらのうち，認可コード・フローの使用の要件は，クライアント・クレデンシャル・フローも使用可能としている FAPI 2.0 よりも望ましい．クライアント・クレデンシャル・フローでは，フィンテック事業者は，自身の認証に成功すれば，顧客の同意の確認や認可コードの発行の処理を経ることなく金融機関（認可サーバ）からアクセス・トークンを入手することができる．したがって，顧客の同意を金融機関がリアルタイムで確認するという点で認可コード・フローの方が望ましく，FAPI 2.0 よりもリスク低減が期待できるといえる．

### 4.4 openFinance API Framework

#### 4.4.1 概要

欧州連合では，オンライン決済のセキュリティ向上などを目的とする欧州決済指令第 2 版（PSD2: Payments Services Directive 2）が 2015 年に成立し，加盟各国が 2018 年 1 月までに国内法を整備することとなった．PSD2 では，金融機関やフィンテック事業者が高いセキュリティを実現する顧客認証（Strong Customer Authentication）を実施するほか，顧客情報をフィンテック事業者（Third Party Provider）にオープン API を介して提供することが金融機関に対して義務づけられた．

PSD2 に準拠するオープン API の仕様は，openFinance API Framework の一部として，域内の各種決済サービスの技術仕様の標準化を担当しているベルリン・グループ（Berlin Group）によって策定されている[19]．セキュリティ要件は API のプロトコルの機能とセキュリティ対策（Protocol Functions and Security Measures）に関するガイドラインに記述されている[20]．このガイドラインは，認可処理に関して OAuth 2.0 に基づくフローの採用をオプションとしているほか，セキュリティ要件集として FAPI を参照していない．これは，域内のさまざまな金融機関やフィンテック事業者が本ガイドラインを活用できるように，API の仕様の自由度をなるべく高めることを意図したものと考えられる．

#### 4.4.2 主なセキュリティ要件

プロトコルの機能とセキュリティ対策に関するガイドラインでは，OAuth 2.0 に基づく認可処理のセキュリティ要件の記載がブラジルやオーストラリアの場合と比べて少ない．セキュリティ対策を検討する際には，OAuth 2.0 向けの最新のベスト・プラクティス[21]を参照することを推奨しており，具体的なセキュリティ要件の設定を各金融機関やフィンテック事業者に委ねる姿勢がうかがわれる．これは，加盟各国における通信環境やサービス形態に差異が存在するなかで，各金融機関やフィンテック事業者がそれぞれ直面している状況に見合ったセキュリティ対策を検討・実施できるようにするためとみられる．

ガイドラインに記載されている主なセキュリティ要件は以下のとおりである．

- 【フィンテック事業者の認証方法】フィンテック事業者を認証する方法として OAuth MTLS を使用する．
  - TLS のバージョンは 1.2 以降とする．
  - 暗号アルゴリズムを選択する際には，アメリカ連邦政府が推奨する暗号強度や各国の IT セキュリティ当局の要求事項を参照する．
- 【各種リクエストへの署名付与】フィンテック事業者は各種リクエストのメッセージに対して署名を付与する．
- 【認可コード・フローの使用】認可の処理フローとして認可コード・フローを使用する．
- 【PKCE の必須化】認可コードの不正使用への対策として PKCE を使用する．

#### 4.4.3 FAPI 2.0 との比較

フィンテック事業者の認証方法および PKCE の必須化の要件は FAPI 2.0 と整合的である．

認可コード・フローの使用に関する要件は，クライアント･クレデンシャル･フローも使用可能としている FAPI 2.0 と比べて，金融機関が顧客の同意をリアルタイムで確認する点で望ましく，リスク低減に資するといえる．

### 4.5 FAPI 2.0 との比較結果のまとめ

本節における比較結果をまとめると以下のとおりである．

- Open Finance（ブラジル）と Consumer Data Right（オーストラリア）のセキュリティ要件集は，①フィンテック事業者のなりすまし防止，②認可リクエストの内容の保護，③認可コードの不正使用防止，④リフレッシュ・トークンの不正使用防止，⑤暗号アルゴリズムによる通信データの保護の観点で，FAPI 2.0 と同等の

© 2026 Information Processing Society of Japan

セキュリティを要求している．

- openFinance API Framework（欧州連合）のガイドラインは，フィンテック事業者のなりすまし防止，および，認可コードの不正使用防止の観点で，FAPI 2.0 と同等のセキュリティを要求している．
- Open Finance のセキュリティ要件集は，アクセス・トークンの有効期間に関する要件を含んでおり，アクセス・トークンの不正使用によるリスクを低減させる観点で FAPI 2.0 よりも望ましい．
- Consumer Data Right のセキュリティ要件集は，アクセス・トークン，各種リクエスト，PAR の不正使用によるリスクの低減，および，顧客の同意確認の確実性の観点で FAPI 2.0 よりも望ましい．
- 欧州連合のガイドラインは，顧客の同意確認の確実性の観点で FAPI 2.0 よりも望ましい．

## 5. おわりに

本稿では，オープン API における認可処理のプロトコルのセキュリティ要件集として標準化された FAPI 2.0 を紹介し，FAPI 2.0 公表以前に策定されている海外のセキュリティ要件集やガイドラインと比較した．その結果，ブラジル（Open Finance）やオーストラリア（Consumer Data Right）のセキュリティ要件集は，FAPI 2.0 と整合的な要件を複数含んでいたほか，FAPI 2.0 よりもリスク低減に資する要件も含んでいた．欧州連合（openFinance API Framework）のガイドラインも，FAPI 2.0 を参照しているわけではないが，FAPI 2.0 と整合的な要件やリスク低減に資する要件を含んでいた．

こうした情報は，本邦金融機関やフィンテック事業者がオープン API の認可処理におけるセキュリティ要件を検討する際に有用である．例えば，アクセス・トークンや各種リクエストの有効期間に関する要件を設定する場合，FAPI 2.0 にはこれらの要件が含まれておらず独自に検討する必要があるが，その際に Consumer Data Right のセキュリティ要件集に含まれている要件を参照することができる．金融機関だけではなく，オープン API 関連のシステムの開発・維持管理を担う本邦ベンダーにおいても有用な情報であろう．

金融機関やフィンテック事業者，API 関連のベンダーにおいては，海外のセキュリティ要件集に関する今後の動向をフォローしつつ，オープン API におけるセキュリティの維持・向上につなげていくことを期待したい．

## 参考文献


[1] “銀行分野のオープン API に係る電文仕様標準について 第 2 版”. https://www.zenginkyo.or.jp/fileadmin/res/abstract/council/openapi/openapi_sp_1.pdf, (参照 2026-06-16).

[2] “Financial-Grade API Security Profile 1.0 – Part 1: Baseline”. https://openid.net/specs/openid-financial-api-part-1-1_0.html, (参照 2026-06-16).

[3] “Financial-Grade API Security Profile 1.0 – Part 2: Advanced”. https://openid.net/specs/openid-financial-api-part-2-1_0.html, (参照 2026-06-16).

[4] “FAPI 2.0 Security Profile”. https://openid.net/specs/fapi-security-profile-2_0-final.html, (参照 2026-06-16).

[5] “Open Banking Read-Write API Profile – v4.0.1”. https://openbankinguk.github.io/read-write-api-site3/v4.0.1/profiles/read-write-data-api-profile.html, (参照 2026-06-16).

[6] “Account and Transaction API Profile – v4.0.1”. https://openbankinguk.github.io/read-write-api-site3/v4.0.1/profiles/account-and-transaction-api-profile.html, (参照 2026-06-16).

[7] “Payment Initiation API Profile – v4.0.1”. https://openbankinguk.github.io/read-write-api-site3/v4.0.1/profiles/payment-initiation-api-profile.html, (参照 2026-06-16).

[8] “FAPI 2.0 Attacker Model”. https://openid.net/specs/fapi-attacker-model-2_0-final.html, (参照 2026-06-16).

[9] “Update on Open Banking”. https://www.gov.uk/government/publications/update-governance-of-open-banking/update-on-open-banking, (参照 2026-06-16).

[10] “Case Studies: Open Banking in Real Life”. https://www.openbanking.org.uk/case-studies, (参照 2026-06-16).

[11] “API Performance Stats”. https://www.openbanking.org.uk/api-performance, (参照 2026-06-16).

[12] “Getting Started – Open Banking API Security Profile”. https://standards.openbanking.org.uk/security-profiles/get-started-obl-api-security-profile, (参照 2026-06-16).

[13] “Qual a Diferença Entre Open Banking e Open Finance?” https://openfinancebrasil.org.br/2022/11/17/qual-a-diferenca-entre-open-banking-e-open-finance, (参照 2026-06-16).

[14] “Open Finance Brasil Financial-Grade API Security Profile 1.0 Implementers Draft 3”. https://openfinancebrasil.atlassian.net/wiki/spaces/OF/pages/245760001/EN+Open+Finance+Brasil+Financial-grade+API+Security+Profile+1.0+Implementers+Draft+3, (参照 2026-06-16).

[15] “Consumer Data Right: Rollout”. https://www.cdr.gov.au/rollout, (参照 2026-06-16).

[16] “Data Standards – Consumer Data Right”. https://dsb.gov.au/consumer-data-right/data-standards, (参照 2026-06-16).

[17] “CDR Data Standards”. https://consumerdatastandardsaustralia.github.io/standards, (参照 2026-06-16).

[18] “OAuth 2.0 Token Introspection”. https://datatracker.ietf.org/doc/html/rfc7662, (参照 2026-06-16).

[19] “PSD2 Access to Bank Accounts”. https://www.berlin-group.org/psd2-access-to-bank-accounts, (参照 2026-06-16).

[20] “openFinance API Framework Implementation Guidelines: Protocol Functions and Security Measures, Version 2.4”. https://c2914bdb-1b7a-4d22-b792-c58ac5d6648e.usrfiles.com/ugd/c2914b_7111d79133ef4d44ae420d9042ec74f7.pdf, (参照 2026-06-16).

[21] “Best Current Practice for OAuth 2.0 Security”. https://www.rfc-editor.org/rfc/rfc9700.html, (参照 2026-06-16).


© 2026 Information Processing Society of Japan